

Threat Model for Aaronic (oil and Energy) Website Using STRIDE analysis

BY:
**ANENE JENNIFER IFUNANYA AND SECURITY
TEAM OF 7 MEMBERS**

Threat Model for Aaronic (oil and Energy) Website Using STRIDE analysis

1. Introduction

This report presents a threat model for Aaronic (Oil and energy) website, outlining potential security risks, vulnerabilities, and mitigation strategies to enhance its security posture.

2. Scope of the Threat Model

The scope of this threat model includes the key components Aaronic (Oil and energy) website:

- **Frontend (User Interface):** Used by clients to register their company and browse through the company's products
- **Backend (Web Server):** Manages user authentication, order processing, and business logic.
- **Database:** Stores user details, product information, and transaction records.

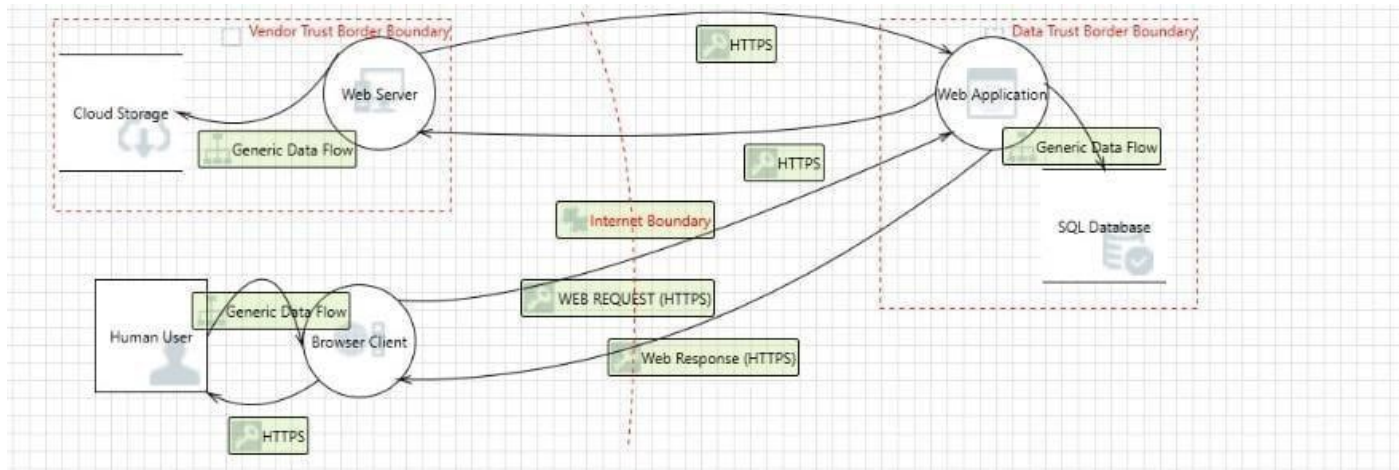
3. Identified Assets

- **User Data:** Personal information, login credentials.
- **Product Data:** Product details, prices, inventory.
- **Website Availability:** Ensuring the website remains operational and accessible.

4. Data Flow Diagram (DFD)

A Data Flow Diagram (DFD) has been created to visualize how data moves within the system and identify potential trust boundaries. The diagram includes:

- **External Entities:** Human User, Browser.
- **Processes:** Browser Client (UI), Web Application, SQL Database.
- **Data Stores:** Vendor Data, Product Data Cloud Storage.
- **Data Flows:** Paths of data transmission between components.



5. Identified Threats (Using STRIDE Model)

Component	Threat	Type (STRIDE)	Description
Admin Login	Credential theft	Spoofing	An attacker might steal user credentials through phishing.
Product Pages	Data tampering	Tampering	Attacker can alter databases, files, or records to manipulate information (e.g., changing financial records or grades).
Database	Unauthorized access	Elevation of Privilege	A user might exploit a vulnerability to gain admin rights.
Website	Denial of Service (DoS)	Denial of Service	An attacker might overload the site to make it unavailable.

6. Identified Vulnerabilities

- Weak password policies allow brute-force attacks.
- Lack of HTTPS encryption exposes data in transit.
- Poor input validation enables SQL Injection attacks.

- Misconfigured access controls may allow unauthorized database access.

7. Risk Evaluation

Threat	Likelihood	Impact	Risk Level
Credential theft	High	High	Critical
Data tampering	Medium	High	High
Unauthorized access	Low	Critical	High
Denial of Service (DoS)	Medium	High	High
Data leakage	Low	Medium	Medium

8. Mitigation Strategies

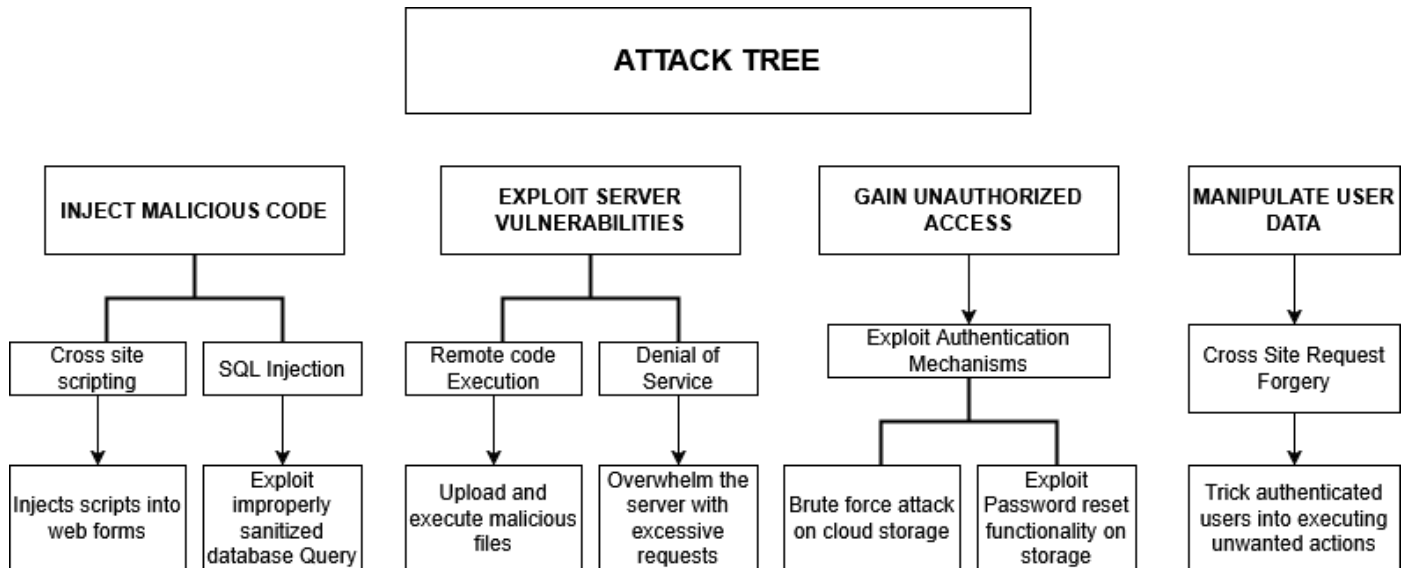
Threat	Mitigation Strategy
Credential theft	Implement multi-factor authentication (MFA) and strong password policies.
Data tampering	Use HTTPS to encrypt data in transit.
Unauthorized access	Implement role-based access control (RBAC) and security audits.
Denial of Service (DoS)	Use rate limiting and DDoS protection services.
Data leakage	Encrypt sensitive data at rest and restrict data access.

9. Attack Tree for Credential Theft

An Attack Tree diagram has been created to illustrate various methods an attacker could use to steal user credentials. The tree structure includes:

- **Injection of malicious code:** This can allow the attacker to manipulate the database, extract sensitive information, or even delete data.
- **Exploit server vulnerabilities:** open ports can be exploited to gain access to the server, Default or weak passwords can be easily cracked.
Running outdated software with known vulnerabilities.

- **Gain Unauthorized access:** Use strong, unique passwords and enable multi-factor authentication (MFA).
- **Manipulate User Data:**
Intrusion Detection Systems: Deploy IDS to monitor network traffic and detect any suspicious activities that may indicate data manipulation attempts.



10. Conclusion

This threat model provides an in-depth analysis of the security threats facing Aaronic (Oil and Energy) website and proposes actionable mitigation strategies. Regular security audits, penetration testing, and continuous monitoring should be implemented to ensure the website remains protected against emerging threats.